COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.8 · Log Data

Mestre CyberSec · **Aula 4.8 — Log Data** (13:41) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Log: firewall (regra/IP/porta); aplicação (login/erro); endpoint (Windows Event, Sysmon); OS (syslog Linux, Event Viewer Windows); network (netflow/DNS queries); proxy log. RETENÇÃO (quanto tempo — por lei/auditoria); PROTEÇÃO (quem lê/altera); centralização no SIEM.

💡 Highlights que a prova CompTIA cobra

- Cole log de TUDO: firewall+app+endpoint+rede+cloud
- Retention por lei: 1 ano é comum; log protegido contra alteração

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'centralized log repository'=SIEM; 'how long to keep'=retention

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.8 — Log Data)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Gestão de Informações e Eventos de Segurança (SIEM)

Plataforma centralizada que coleta, agrega, correlaciona e analisa logs de firewalls, endpoints, aplicações, rede e nuvem em tempo real. Fornece alertas, dashboards e capacidade de busca forense em toda a organização.

⚠️ ***Armadilha CompTIA:*** *Qualquer menção a 'centralized log repository', 'aggregate logs from multiple sources' ou 'correlate events' = SIEM. É a resposta padrão para centralização de logs.*

• Syslog (Protocolo de Registro de Eventos) (SYSLOG)

Protocolo padrão de logs (RFC 5424) usado principalmente em sistemas Linux/Unix e dispositivos de rede para enviar mensagens de evento a um servidor central de logs. Mensagens são categorizadas por facility e nível de severidade, usando tipicamente UDP porta 514.

⚠️ ***Armadilha CompTIA:*** *Linux + dispositivos de rede (roteadores, switches) = Syslog. Se a questão fala de logs de Linux ou envio de logs para servidor remoto, pense em Syslog, não em Event Viewer.*

• Visualizador de Eventos do Windows (N/A)

Ferramenta nativa do Windows para visualizar logs de eventos do sistema operacional, aplicações e segurança. Logs principais: Application, System e Security (que registra logons, uso de privilégios e eventos de auditoria).

⚠️ ***Armadilha CompTIA:*** *Windows = Event Viewer / Event Logs; Linux = Syslog. Logons e eventos de auditoria no Windows estão no log de SECURITY. Não confunda os dois ecossistemas.*

• Monitor do Sistema (Sysmon) (SYSMON)

Ferramenta do Windows Sysinternals que fornece logs detalhados de endpoint além do Event Viewer padrão, capturando criação de processos, conexões de rede, alterações de arquivos e carregamento de drivers. Muito usada para threat hunting e detecção de atividade maliciosa.

⚠️ ***Armadilha CompTIA:*** *Se a questão pede logs DETALHADOS de endpoint (processos criados, conexões de rede por processo), a resposta é Sysmon, não o Event Viewer padrão.*

• NetFlow (Dados de Fluxo de Rede) (N/A)

Tecnologia de log de rede que coleta metadados sobre fluxos de tráfego: IPs origem/destino, portas, protocolos e volume — sem capturar o conteúdo dos pacotes. Usada para análise de tráfego e detecção de comportamento anômalo.

⚠️ ***Armadilha CompTIA:*** *'Traffic metadata', 'who talked to whom, on which port, how much data' = NetFlow. Ele mostra metadados de fluxo, NÃO o conteúdo (isso seria packet capture/PCAP).*

• Retenção de Logs (N/A)

Política que define por quanto tempo os logs devem ser armazenados antes de arquivamento ou exclusão. Períodos de retenção são definidos por requisitos legais, regulatórios e de auditoria (um ano é comum), equilibrando conformidade e custo de armazenamento.

⚠️ ***Armadilha CompTIA:*** *'How long to keep logs?' = retention policy. A resposta quase sempre envolve leis/regulamentações/auditoria, não preferência técnica. Retenção varia por tipo de log e setor.*

• Integridade e Proteção de Logs (WORM)

Controles que garantem que logs não possam ser alterados ou apagados após a criação, como armazenamento Write Once Read Many, hashing, assinaturas digitais e listas de controle de acesso restritas. Proteger a integridade é crítico porque atacantes tentam apagar evidências.

⚠️ ***Armadilha CompTIA:*** *Perguntas sobre 'prevent log tampering' ou 'who can read/modify logs' apontam para integridade: WORM, hashing, acesso restrito e envio imediato ao SIEM (fora do alcance do atacante que comprometeu o host).*

• Logs de Proxy (N/A)

Logs gerados por proxies forward e filtros web que registram cada URL requisitada, identidade do usuário, timestamps, categorias e decisões de filtragem/bloqueio. Essenciais para investigar ameaças via web, exfiltração de dados e violações de uso aceitável.

⚠️ ***Armadilha CompTIA:*** *Se a questão pergunta 'which log shows which websites a user visited' ou 'URL filtering decisions', a resposta é proxy log — não firewall log (que mostra IPs/portas, não URLs completas).*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de SOC em uma empresa de serviços financeiros está revisando logs de firewall após receber um alerta sobre tráfego de saída suspeito. O alerta indica que uma regra específica do firewall foi acionada. Qual campo na entrada do log do firewall identificará diretamente qual política ou regra do firewall fez com que o tráfego fosse permitido, negado ou descartado?

A) O endereço IP de destino

B) O endereço MAC de origem

C) O ID da regra, nome da política ou campo de ação

D) O valor TTL (Time To Live) do pacote

QUESTÃO 2 · CENÁRIO DE EXAME

Um respondente de incidentes precisa determinar qual processo gerou um executável suspeito em uma estação de trabalho Windows, incluindo a relação processo pai-filho e os argumentos completos de linha de comando usados. O log de Segurança padrão não contém esse nível de detalhe. Qual ferramenta a equipe de segurança deve implantar para capturar essa telemetria de endpoint?

A) Visualizador de Eventos do Windows apenas com o log de Aplicação

B) Performance Monitor (perfmon)

C) Microsoft Sysmon (System Monitor)

D) Logs históricos do Gerenciador de Tarefas

QUESTÃO 3 · CENÁRIO DE EXAME

Uma organização de saúde de médio porte possui logs espalhados entre servidores individuais, firewalls e endpoints. Os analistas estão perdendo ataques correlacionados porque um login de força bruta na VPN e um download subsequente de malware em um endpoint nunca são analisados em conjunto. Qual mudança arquitetônica resolve melhor essa lacuna?

A) Aumentar o tamanho do arquivo de log local em cada servidor

B) Encaminhar todas as fontes de log para um SIEM centralizado para correlação

C) Desativar o registro detalhado para reduzir ruído

D) Rotacionar logs com mais frequência em cada dispositivo

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa que processa transações de cartão de crédito deve cumprir o Requisito 10.5.1 do PCI DSS referente à retenção de logs de auditoria. O oficial de conformidade pede à equipe de segurança que verifique se os trilhos de auditoria estão sendo mantidos pelo período mínimo correto. Por quanto tempo, no mínimo, os logs de auditoria do PCI DSS devem ser retidos?

A) 30 dias

B) 90 dias

C) Pelo menos 12 meses (1 ano)

D) 7 anos

QUESTÃO 5 · CENÁRIO DE EXAME

Um arquiteto de segurança deve projetar uma solução de armazenamento de logs que impeça qualquer usuário — incluindo administradores de domínio — de modificar ou excluir entradas de log após serem gravadas, a fim de atender aos requisitos de preservação legal e cadeia de custódia. Qual característica de armazenamento a solução deve fornecer?

A) Redundância RAID-6

B) Imutabilidade Write Once, Read Many (WORM)

C) Criptografia AES-256 em repouso

D) Backups diários em fita para um cofre externo

QUESTÃO 6 · CENÁRIO DE EXAME

Um engenheiro de rede precisa capturar metadados do fluxo de tráfego (IPs e portas de origem/destino, contagens de pacotes, contagens de bytes, timestamps) do roteador de núcleo para alimentar o SIEM e detectar anomalias volumétricas e comportamento de beaconing. Payloads completos de pacotes não são necessários e armazená-los seria inviável financeiramente. Qual é a tecnologia mais apropriada?

A) PCAP completo em todas as portas span

B) Exportação de NetFlow (ou IPFIX) do roteador

C) Apenas polling SNMP de contadores de interface

D) Encaminhamento de syslog do kernel do roteador

QUESTÃO 7 · CENÁRIO DE EXAME

Um analista de segurança está monitorando um controlador de domínio Windows em busca de possíveis ataques de password spraying. Qual ID de evento específico no log de Segurança do Windows indica uma tentativa de logon com falha e deve ser agregado pelo SIEM para detectar essa atividade?

A) 4624 - Uma conta foi conectada com sucesso

B) 4625 - Falha ao conectar uma conta

C) 4634 - Uma conta foi desconectada

D) 4648 - Um logon foi tentado usando credenciais explícitas

QUESTÃO 8 · CENÁRIO DE EXAME

Um administrador Linux está configurando o rsyslog para encaminhar eventos de autenticação (como logins SSH e uso de sudo) do arquivo auth.log para o SIEM central. Qual facilidade (facility) do syslog deve ser usada para garantir que o SIEM categorize e analise corretamente essas mensagens relacionadas à autenticação?

A) auth (ou authpriv)

B) kern

C) daemon

D) user

QUESTÃO 9 · CENÁRIO DE EXAME

Uma investigação de DLP (Data Loss Prevention) revela que um funcionário exfiltrou documentos confidenciais de design para uma conta pessoal de armazenamento em nuvem usando HTTPS. O firewall não consegue inspecionar o payload criptografado. No entanto, o proxy web registrou cada URL solicitada. Qual campo do log é mais ��til para reconstruir a atividade web do usuário durante o incidente?

A) Tempo de concessão DHCP do endpoint

B) Contadores de bytes do NetFlow

C) Entradas de URL, usuário e timestamp do log do proxy

D) Apenas o Event ID 4688 do Windows

QUESTÃO 10 · CENÁRIO DE EXAME

A inteligência de ameaças alertou sobre uma família de malware que usa tunelamento DNS para se comunicar com seu servidor de comando e controle. Os logs do resolvedor DNS estão sendo encaminhados ao SIEM. Qual padrão nos logs de DNS mais provavelmente indicaria essa atividade de tunelamento?

A) Um alto volume de respostas NXDOMAIN para rótulos de subdomínio curtos e aleatórios sob um único domínio pai

B) Um pequeno número de respostas A para domínios conhecidos como google.com

C) Consultas PTR reversas para nomes de hosts internos

D) Respostas AAAA (IPv6) para servidores locais

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — O ID da regra, nome da política ou campo de ação

O ID da regra, nome da política ou campo de ação identifica diretamente qual regra do firewall foi correspondida. Os IPs de origem/destino apenas identificam endpoints, e o TTL é um campo da camada de rede não relacionado a decisões de política. Sem o identificador da regra, os analistas não conseguem determinar se o tráfego foi bloqueado ou permitido e por quê.

Questão 2: Alternativa C — Microsoft Sysmon (System Monitor)

O Microsoft Sysmon é um serviço de sistema e driver de dispositivo do Windows que registra criações detalhadas de processos (Event ID 1), incluindo processo pai, linha de comando, hashes e conexões de rede — muito além do log de Segurança padrão. O Performance Monitor rastreia contadores de recursos, o Gerenciador de Tarefas não retém dados históricos de processos e o log de Aplicação carece de informações de ancestralidade de processos.

Questão 3: Alternativa B — Encaminhar todas as fontes de log para um SIEM centralizado para correlação

Um SIEM (Security Information and Event Management) centraliza a ingestão de logs de fontes distintas e correlaciona eventos usando regras e análises — essencial para detectar ataques em múltiplos estágios que abrangem firewalls, autenticação e hosts. Logs locais maiores, rotação mais rápida ou desativar o registro não permitem correlação entre fontes.

Questão 4: Alternativa C — Pelo menos 12 meses (1 ano)

O Requisito 10.5.1 do PCI DSS v4.0 obriga a retenção de logs de auditoria por pelo menos 12 meses, com os 3 meses mais recentes imediatamente disponíveis para análise. 30 ou 90 dias não satisfazem o padrão; 7 anos é a retenção para alguns registros financeiros, mas não o mínimo do PCI DSS.

Questão 5: Alternativa B — Imutabilidade Write Once, Read Many (WORM)

O armazenamento WORM (Write Once, Read Many) impõe imutabilidade, de modo que os dados, uma vez gravados, não podem ser alterados ou excluídos — nem mesmo por administradores — atendendo aos requisitos de cadeia de custódia e preservação legal. O RAID-6 protege contra falha de disco, mas permite modificação; a criptografia protege a confidencialidade, mas não a integridade contra adulteração; backups isolados não impedem a modificação in-loco dos logs atuais.

Questão 6: Alternativa B — Exportação de NetFlow (ou IPFIX) do roteador

O NetFlow (e seu sucessor IPFIX) exporta metadados por fluxo — IPs, portas, contagens de pacotes/bytes, timestamps e protocolo — ideais para análises de SIEM, detecção de anomalias e retenção de longo prazo devido ao seu tamanho compacto. PCAP completo é caro demais para armazenar em escala; contadores SNMP carecem de granularidade por fluxo; syslog de um roteador normalmente contém apenas eventos do dispositivo, não fluxos de tráfego.

Questão 7: Alternativa B — 4625 - Falha ao conectar uma conta

O Event ID 4625 é registrado cada vez que uma tentativa de logon falha e inclui o IP de origem, nome da conta, tipo de logon e motivo da falha — perfeito para correlacionar padrões de password spraying. 4624 é um logon bem-sucedido (o sinal oposto), 4634 é um logoff, e 4648 representa uso explícito de credenciais, que não é o indicador principal de tentativas com falha.

Questão 8: Alternativa A — auth (ou authpriv)

A facilidade 'auth' (e 'authpriv' para mensagens sensíveis) é a classificação syslog padrão para eventos de autenticação, autorização e sudo em Linux/UNIX. 'kern' é para mensagens do kernel, 'daemon' para daemons do sistema e 'user' é a facilidade genérica padrão — nenhuma identifica especificamente eventos de autenticação para o correto parsing do SIEM.

Questão 9: Alternativa C — Entradas de URL, usuário e timestamp do log do proxy

Os logs de proxy registram a URL solicitada, o usuário autenticado, o timestamp e os códigos de resposta — mesmo quando o payload é criptografado via HTTPS — tornando-os a fonte primária para reconstrução da atividade web. Dados de concessão DHCP mostram endereçamento, o NetFlow mostra volume/portas (não URLs) e o Event ID 4688 mostra criação de processos, nenhum dos quais revela a URL de destino.

Questão 10: Alternativa A — Um alto volume de respostas NXDOMAIN para rótulos de subdomínio curtos e aleatórios sob um único domínio pai

O tunelamento DNS tipicamente se manifesta como um alto volume de consultas para subdomínios de alta entropia (aparentemente aleatórios) sob um único domínio controlado pelo atacante, com muitas respostas NXDOMAIN devido à

natureza codificada/fragmentada dos dados. Consultas A normais para sites populares, consultas PTR para hosts internos e respostas IPv6 para servidores locais são padrões de tráfego rotineiros, não indicadores de tunelamento.